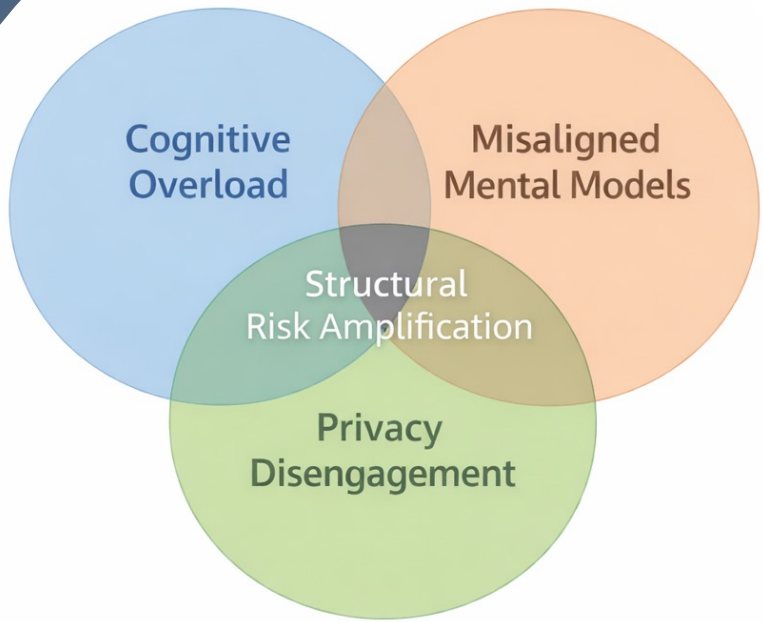
Designing Usable and Ethical Security Strategies for a Local Start-Up

A Socio-Technical Approach

Pragadheesh Marimuthu

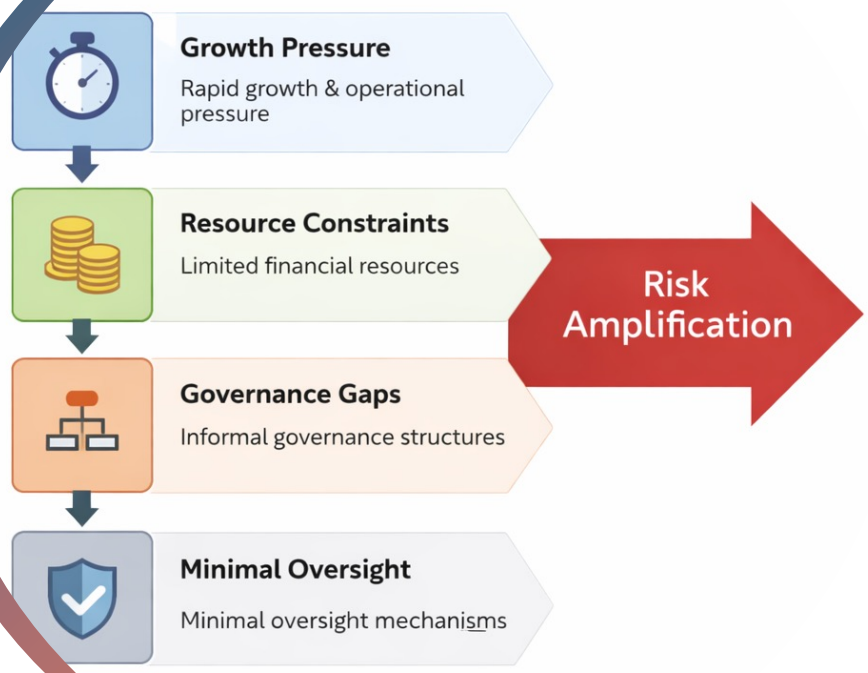
The Human Factor – Individual Presentation



Human Factors as Strategic Risk Drivers

Key Human Vulnerabilities

- Cognitive overload & decision fatigue
- Misaligned mental models
- Behavioural disengagement in privacy
- Interaction between cognition, system design, and culture



The Start-Up Risk Context

Why Start-Ups Amplify Human Risk

- Rapid scaling and sustained operational pressure
- Resource scarcity and competing operational priorities
- Informal governance and policy immaturity
- Limited monitoring and accountability mechanisms

Under these conditions, socio-technical vulnerabilities are structurally amplified rather than effectively mitigated.

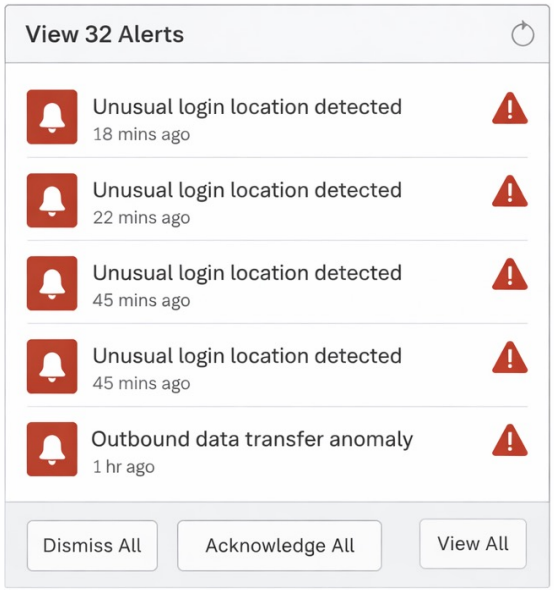
Designing for Cognitive Limitations (Anchored to Johnson, 2021; CERT, 2013)

Reducing cognitive overload through:

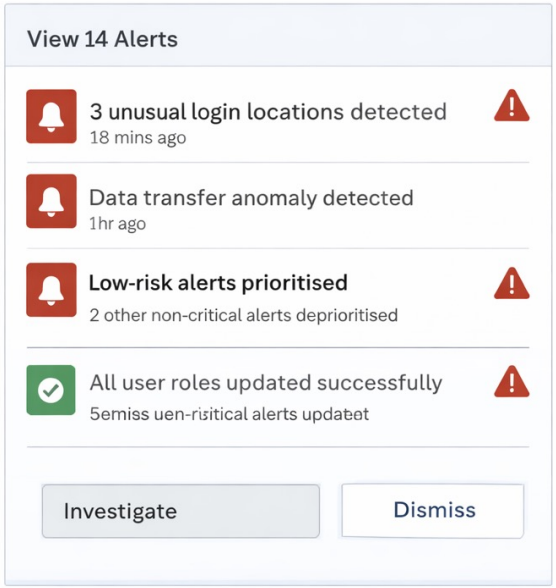
- Security-by-default configuration
- Alert prioritisation
- Automated handling of low-risk decisions
- Role-based access control

Effective security design reduces cognitive burden rather than shifting complexity onto users.

Before



After

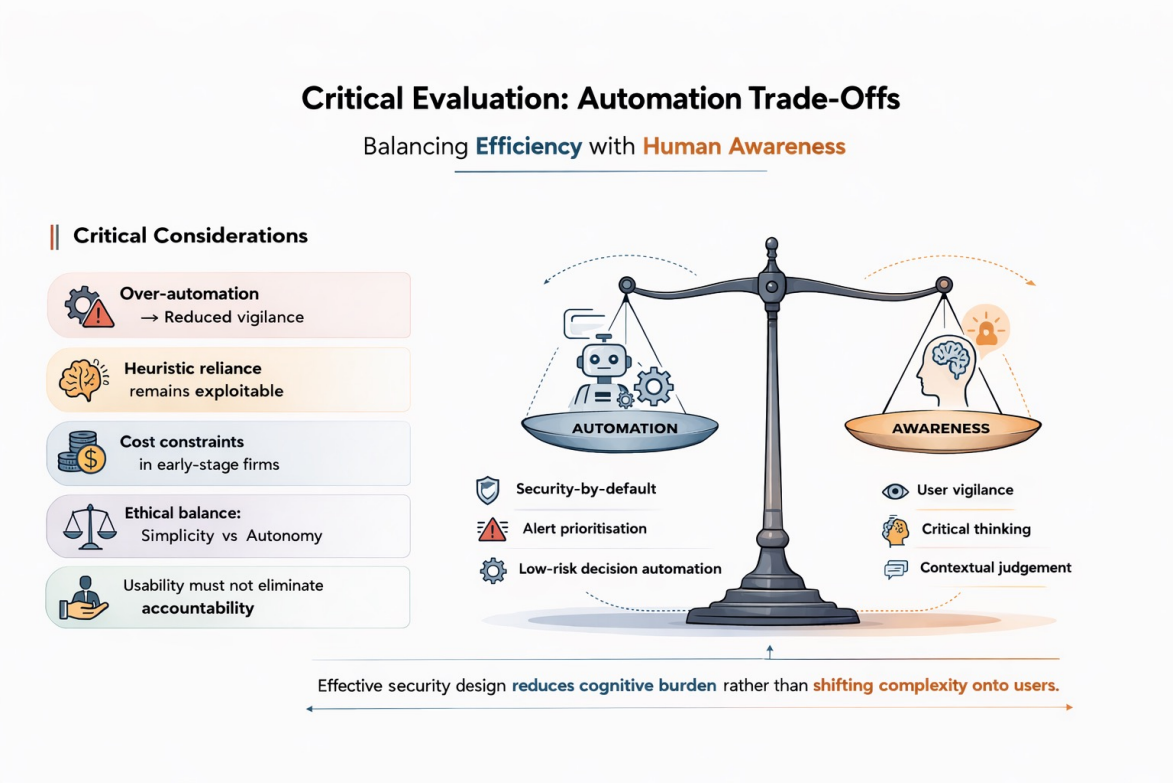


Critical Evaluation: Automation Trade-Offs

Critical Considerations

- Over-automation may reduce user vigilance and skill retention
- Heuristic reliance and bias remain exploitable
- Early-stage firms face financial and implementation limitations
- Ethical tension: simplicity versus user autonomy
- Usability must not displace accountability and oversight

Automation should optimise routine decisions while preserving human oversight in high-risk contexts.

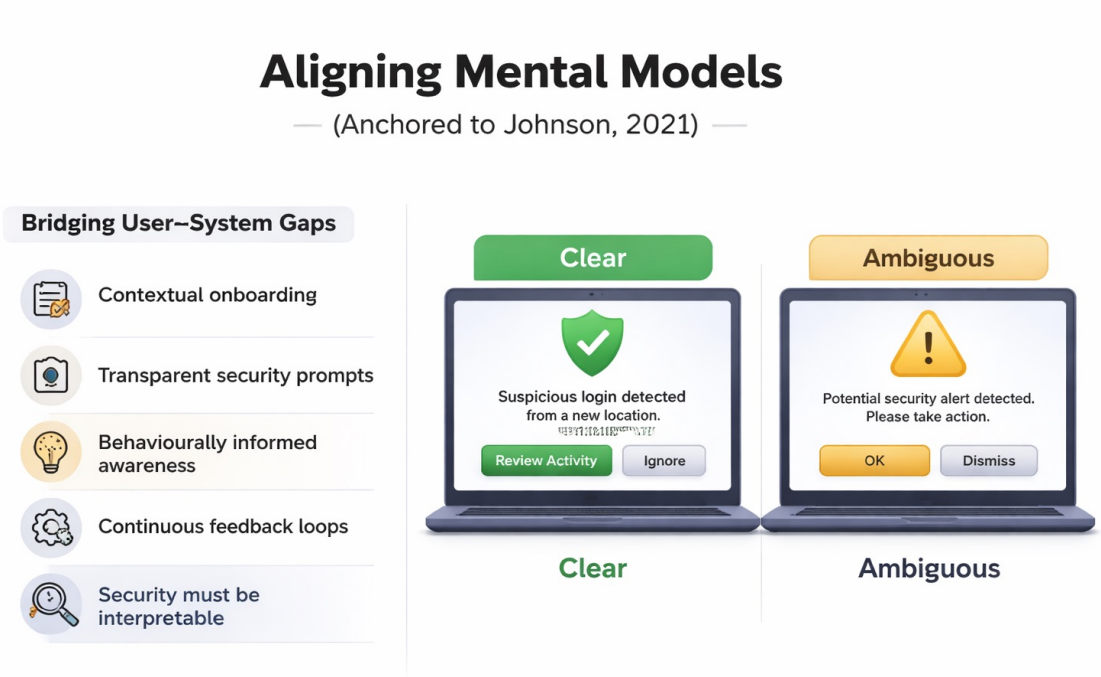


Aligning Mental Models

Bridging User–System Gaps*(Anchored to Johnson, 2021)*

- Contextual onboarding that builds accurate expectations
- Transparent, consequence-focused security prompts
- Behaviourally informed nudges to correct misaligned mental models
- Continuous feedback loops to reinforce learning

When system signals are ambiguous, users rely on flawed assumptions rather than informed judgement.

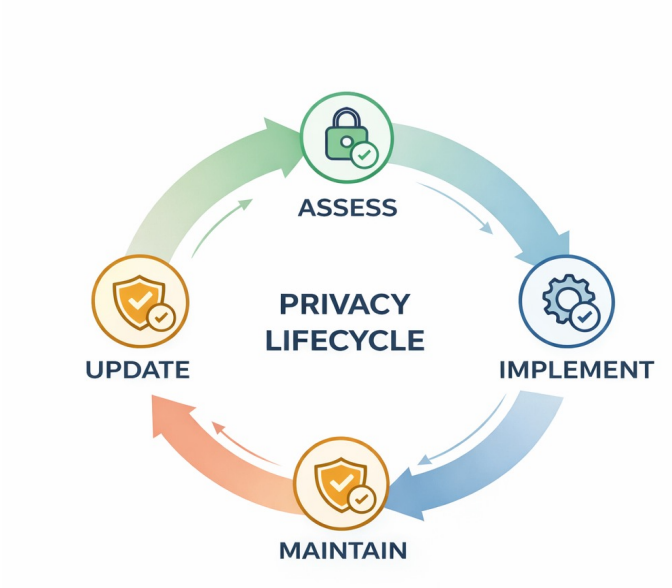


Re-Engaging Privacy Practices *(Anchored to DCMS, 2019)*

Embedding Privacy by Design

- Privacy-by-default configurations that minimise user burden and error potential
- Data minimisation principles
- Meaningful, context-aware consent rather than checkbox compliance
- Structured third-party risk assessment and contractual oversight

Privacy must be engineered into systems rather than retrofitted after incidents occur.

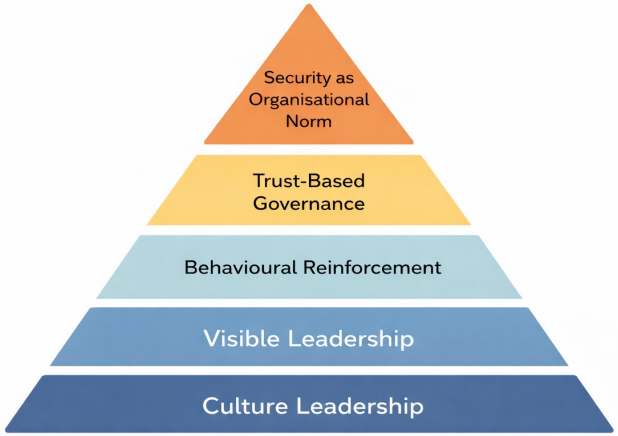


Building Sustainable Security Culture

Security as an Organisational Norm

- Leadership modelling behaviour to signal security priorities
- Social reinforcement mechanisms that normalise secure practice
- Behaviourally informed nudging mechanisms
- Trust-based governance rather than surveillance

Culture determines whether security is perceived as a shared responsibility or an imposed constraint.

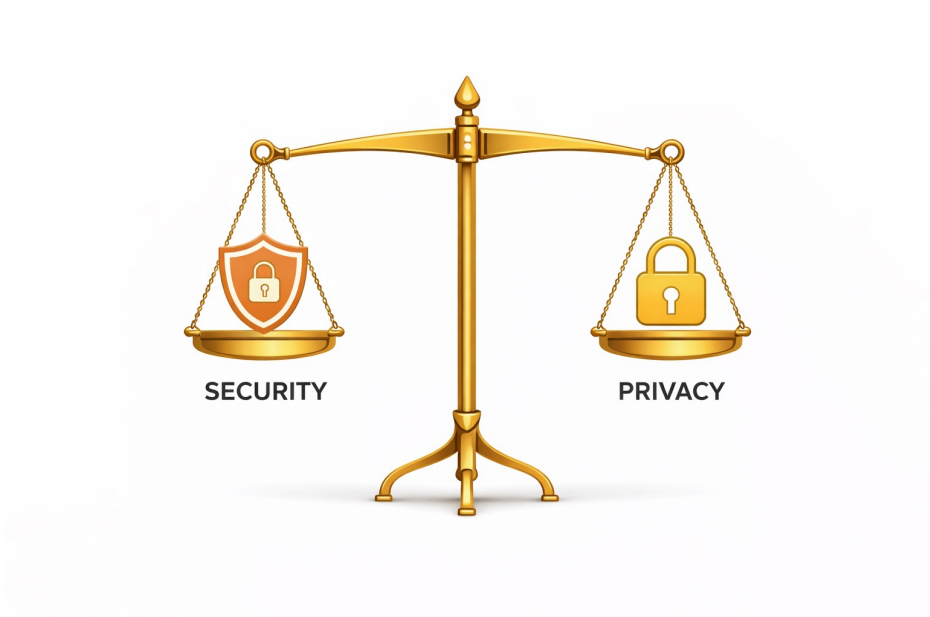


Social & Ethical Considerations

Ethical Dimensions of Usable Security

- Balancing surveillance with employee autonomy
- Monitoring must be proportionate, necessary, and justified
- Explainability is essential where automated decisions affect users
- Alignment with GDPR principles and lawful processing

Usable security should protect users without eroding trust or dignity.



Integrated Socio-Technical Strategy

Integrated Framework

- **Human Cognition** - recognising cognitive limits and behavioural tendencies in security decision-making
- **Technology Design** - systems designed to reduce complexity and support secure behaviour
- **Organisational Culture** - leadership norms and practices that reinforce secure actions
- **Ethical Governance** - transparency, accountability, and responsible oversight in security implementation
- Security resilience emerges when **human, technical, and organisational elements are aligned rather than treated in isolation.**

Human factors must therefore be treated as strategic risk drivers, not operational afterthoughts.

Key Takeaways

Designing Sustainable Security

Human behaviour plays a central role in cybersecurity risk

Usable security reduces cognitive burden and improves compliance

Security systems must align **technology, human behaviour, and organisational culture**

Ethical and transparent governance strengthens trust and accountability

Effective cybersecurity emerges from integrating human, technical, and organisational dimensions rather than treating them in isolation.

Thank you for your time and attention.

References

CERT Insider Threat Team (2013) Unintentional insider threats: A foundational study. Software Engineering Institute.

Hughes-Lartey, K., Li, M., Botchey, F.E. and Qin, Z. (2021) ‘Human factor, a critical weak point in the information security of an organisation’s Internet of Things’, Heliyon, 7(3).

Johnson, J. (2021) Designing with the mind in mind. 3rd edn. Waltham, MA: Morgan Kaufmann.

UK Department for Digital, Culture, Media & Sport (2019) Cyber security breaches survey 2019.